

PhishProbe

Check a suspicious link — without opening it yourself.

Disposable sandbox on Vultr

AI verdict: safe · suspicious · phishing

Vultr: Agent Rush · Challenge 01 — Blast Radius Zero

🎯 THE PROBLEM

"Your parcel couldn't be delivered. Click here."

Almost everyone gets these texts and emails. One tap can leak your card details or install malware. The people most at risk — older relatives, small businesses with no IT team — can't tell a real link from a trap.



You can't tell

A phishing URL looks almost identical to the real one.



Opening = risk

Checking it yourself means visiting the attacker's page.



No safety net

No IT department, no filter, no second opinion.

💡 THE SOLUTION

An AI agent opens the link for you — safely.

Paste the link instead of clicking it. The agent visits it inside a throwaway browser in an **isolated Docker sandbox on Vultr**, follows every redirect, screenshots the page, analyses it, and returns a plain-language verdict.



No signs of danger

Nothing suspicious found — not a safety guarantee.



Suspicious

Mixed signals worth a closer look.



Phishing / dangerous

"Imitates a parcel service, asks for card data, wrong domain."

⚙ HOW IT WORKS

Two checks — fast first, deep second

⚡ Stage 1 · under 1 second

Quick check

Pure URL heuristics — homoglyphs (`paypa1`), shady TLDs, raw-IP hosts, deep subdomains, shorteners, lure words — plus a cache. No browser. This is what the browser extension calls on every link.

🧪 Stage 2 · in the sandbox

Deep scan

The agent really opens the page: full redirect chain, desktop + mobile screenshots, form/field map, network log, blocked downloads. A **vision model** + text model produce the verdict. Streams live to the UI over SSE.

🔑 The agent loop (all LLM calls) runs in the **orchestrator**, never in the sandbox. The sandbox only performs browser actions and returns data.

ARCHITECTURE

Everything runs on a Vultr VM

VULTR CLOUD COMPUTE VM · Ubuntu + Docker

Caddy · auto-HTTPS
web (Next.js) · live SSE view · /demo

→

api · FastAPI orchestrator
quick check · agent loop · verdict engine
holds the Vultr Inference key — nowhere else

→

sandbox
throwaway · Playwright + Chromium
no secrets · non-root · read-only

↑ LLM via Vultr Serverless Inference

Text model = verdict · vision model = screenshot analysis. Only the **api** talks to it.

↓ Sandbox → untrusted URL (internet only)

One container per scan · isolated network · internal IPs blocked · destroyed after.

🧯 CONTAINMENT · THE HEART OF THE SCORING

Blast Radius Zero

Visiting an attacker-controlled page *is* the product — so containment is the product. A compromised page finds nothing to steal and can't break out.

🔒

No secrets

The LLM key lives only in the orchestrator. Sandbox starts with `environment={}`.

🚫

No internal access

Can't reach host, api/db, private IPs or the metadata endpoint — blocked in-sandbox *and* by host iptables.

⏱️

Hard limits

Non-root, read-only, `cap_drop=ALL`, mem/CPU/PID + per-scan & per-action timeouts.

⬇️

Downloads blocked

Download events are logged and cancelled; nothing ever hits disk.

🧬

Injection-proof

Page content enters the prompt as fenced DATA. "Say SAFE" → forced 🔴, a deterministic hard floor.

💥

Destroyed after

Logs saved, then `kill() + remove()` after every single scan.

BUILT ON VULTR

Vultr is the control plane — not just hosting

Cloud Compute VM	The entire control plane. Runs Caddy, the Next.js frontend, the FastAPI orchestrator, and launches/destroys every sandbox container via the Docker SDK.
Serverless Inference	**Every** LLM call. OpenAI-compatible endpoint. A text model produces the verdict; a vision model analyses screenshots ("which brand does this imitate? login/payment page?").
Docker on the VM	One throwaway, isolated sandbox container per scan. Built from `./sandbox`, torn down after each run.

No Claude / OpenAI / other provider is called from the product — all inference goes through `api/agent/llm.py`, which only ever talks to Vultr.

📈 BUSINESS & ROADMAP

From one link to a safety layer for everyone

👵

Consumers

Especially older people who get parcel, bank and government texts. Paste & check.

🏪

Small businesses

No IT team. Staff get phishing mail. A second opinion in one click.

🧩

B2B API

Mail filters & IT providers embed the same quick-check + deep-scan API.

Roadmap

- **Chrome extension** (already prototyped) — right-click → check, a 🟢/🟡/🔴 badge on every page.
- **Freemium** for consumers, **paid B2B API** for mail filters and IT service providers.



PhishProbe

One link. Zero blast radius. Built on Vultr.

🌐 192.248.159.54.nip.io

💻 github.com/swulfen13/phishprobe

An aid, not a security guarantee. 🟢 means "no signs of danger found".